

Change record — P8 Backup, Recovery and Disaster Recovery

Retroactive change record, written to the standard Halden uses for every change (it feeds the change log and the P10 governance dashboard). The same standard is used for every project; in a small company the same person often proposes and approves, and that separation is documented honestly rather than pretended. Halden Distribution Ltd. is a fictional company.

Field	Value
Change ID	CHG-2026-006
Title	P8 — Backup, recovery and DR: 3-2-1-1-0 strategy, hardened backup server, immutable off-site copy, automated restore verification
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; approval pending</i>)
Date raised	2026-10-02
Planned implementation	2026-10-02 onwards, phase by phase (Phase 0 → Phase 5)
Category / risk	Resilience and security — High risk (touches Tier 0 identity, all data, and the recovery capability itself)
Affected services	None during build (backups are additive). In a restore or drill: any system being recovered
Affected systems	New: BKP01, the off-site object-store VM, the sandbox network. Touched: HOST01, DC01, DC02, FS01, LNX01, OPS01, SIEM01, FW01

1. Description of the change

Design and implement a **3-2-1-1-0** backup strategy for Halden with verified restores:

- A **Business Impact Analysis** with each department, producing recovery targets per system.
- A hardened backup server (BKP01) that is **not domain-joined**, is reachable only on the backup ports, and holds an encrypted repository.
- Backups per tier: virtual-machine level, file level, and an ****application-consistent** backup of the domain** (system state) to enable a proper directory restore.
- An **immutable off-site copy** (object storage with a deletion lock) plus a monthly **offline** copy on encrypted removable media.
- **Automated weekly restore verification** that restores files and a virtual machine, checks them, and reports to monitoring.
- An **AD recovery** capability (deleted-object restore and authoritative restore) and a **DR runbook**

tested with a **timed drill** against the agreed targets.

Nothing in the current environment is removed; the existing USB copy is replaced by this arrangement when the new design is proven.

2. Reason for the change

Halden currently has a nightly copy of the file server to a USB disk on the same server, running under a Domain Admin account, and it has **never been tested**. The domain controllers are not backed up at all, and there are no agreed recovery targets. That is a recovery capability in name only: in an attack, the backup shares the domain's fate and can be destroyed with it. Backups are the specific target of a large majority of ransomware attacks, so an untested, domain-joined, on-line-only backup is the exact scenario this project exists to remove.

3. Impact and risk

Area	Impact	Mitigation
Users	None in normal operation; a drill will use isolated sandbox systems	Drills run on scratch virtual machines on an isolated network with no uplink
Identity (Tier 0)	A restore of a domain controller is the riskiest operation in the project	Restores are performed in the sandbox first, scanned, then promoted; restore points are never older than the tombstone lifetime
Data	A wrong restore point could restore stale data over live data	File restores go to a scratch location and are checked before being put back; drill "damage" is simulated by reverting snapshots, never by deleting the only copies
Backup credentials	A compromise of the backup account could threaten the copies	The backup server is not domain-joined; credentials are separate and least-privilege; the off-site copy is immutable and cannot be deleted by that account
Monitoring	A failed restore test must not be missed	The test pushes to monitoring and raises a high alert on failure

4. Implementation plan (phases)

Phase	Work	Window	Verification
0	Business Impact Analysis, tiers and recovery targets	2026-10-02	Targets documented and submitted for approval
1	Harden BKP01; repository storage; backup jobs per tier; domain system-state backup	Out of hours	Jobs produce restore points; repository reachable; backup server confirmed not domain-joined
2	Off-site immutable copy; retention; offline copy; immutability proof	Out of hours	A deletion attempt with backup credentials is refused ; a recovery via version rewind succeeds
3	Automated weekly restore verification and monitoring hand-off	Out of hours	Restore test produces a JSON/HTML result and a monitoring heartbeat

Phase	Work	Window	Verification
4	Active Directory recovery drills (deleted object, authoritative restore)	Out of hours	A deleted object is restored; the authoritative procedure is performed in the sandbox
5	DR runbook and timed ransomware recovery drill	Out of hours	Runbook followed end to end by the timer; timings recorded against the targets

5. Test plan (acceptance)

1. Attempt to delete the immutable off-site copy with the backup account credentials — **must fail**.
2. Attempt to clear or shorten the retention lock — **must fail**, even for the highest-privilege account.
3. Recover the "deleted" repository from before the attempt — the repository and its restore points are intact.
1. Restore a sample of files and compare their hashes with the values recorded at backup time — all match.
2. Restore a virtual machine into an isolated sandbox, boot it, and pass a service health check.
3. Restore a deleted Active Directory object from the directory recycle bin.
4. Follow the DR runbook end to end in a timed drill, and record the recovery time per system against the agreed targets.

6. Backout plan

- **Before every phase:** a hypervisor snapshot of each virtual machine the phase touches (`snap-p8-ph<N>-before`). Backout is to revert the snapshot and re-run the previous phase's scripts, which are idempotent.
- **BKP01:** backout is to revert the backup server's snapshot. Because the repository is additive and encrypted, reverting it does not endanger production data.
- **Restore drills:** the rollback is to **destroy the scratch environment** (remove the sandbox virtual machine and delete the scratch restore folder). Nothing in production is changed, so there is nothing to back out.
- **Off-site copy:** Object Lock is intentional and irreversible within its retention. It is never removed to make a step easier; the lock is the control being proven.
- **Domain controllers:** fixed forward where possible. Reverting a domain controller snapshot can disturb replication, so it is a last resort and is recorded.

7. Post-implementation review

To be completed when the last phase is verified: actual completion date, acceptance test results, anything that went wrong, whether any phase overran, and the measured recovery times against the targets. **All of it is recorded in `../README.md` with a source file for every number.** Until then the results table reads "not measured".

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test results are real; the business approval line represents the lab owner's decision, not a real customer sign-off.

Halden Distribution Ltd. — home-lab portfolio artifact (fictional company, real configurations). Generated from p08-change-record.md on 2026-10-02.